

Análise de Requisitos

Sistema FarmaCerta — gestão de uma rede de farmácias

Base da análise: código-fonte, README.md, scripts SQL e estrutura das telas disponíveis no repositório.

Data: 15 de setembro de 2026

Escopo observado: aplicação PHP 8.2/Apache, MySQL, HTML/CSS/JavaScript, com perfis administrador, gerente e balconista.

Multi-farmácia

Vendas

Estoque

Auditoria

Relatórios

1. Sumário executivo

O FarmaCerta é um sistema web acadêmico para operação de uma rede de farmácias. A solução centraliza unidades em um único banco MySQL e separa os registros operacionais por `farmacia_id`. O núcleo funcional já contempla cadastro e administração de unidades, gestão de produtos e categorias, lotes e validade, entradas de mercadoria, clientes, vendas, cancelamentos, relatórios, auditoria e dados fiscais.

O maior valor de negócio está no fluxo integrado entre venda, estoque e rastreabilidade: a venda reduz o estoque, associa itens a lotes e o cancelamento devolve os produtos. Para uso produtivo, ainda são necessários reforços de segurança, validação, concorrência, integração fiscal oficial, política de backup/restauração e testes automatizados.

2. Objetivos e partes interessadas

Parte interessada	Objetivos e necessidades
Administrador da rede	Manter farmácias, usuários administrativos, visão geral, auditoria e backup SQL.
Gerente da farmácia	Controlar catálogo, fornecedores, funcionários, clientes, estoque, lotes, entradas, vendas, relatórios e informações fiscais.
Balconista	Consultar produtos, atender clientes, montar carrinho, concluir vendas e consultar históricos.
Cliente final	Receber atendimento, compra registrada, recibo e histórico associado quando aplicável.
Contabilidade/fiscal	Consultar dados e status de NF-e/NFC-e e relatórios de vendas.

3. Escopo funcional

3.1 Acesso e administração

- Login por usuário, senha e função (administrador, gerente ou balconista).
- Controle de sessão e redirecionamento para a área inicial do perfil.
- Cadastro, edição e ativação/inativação de farmácias, gerentes e balconistas.
- Auditoria de operações relevantes e backup SQL sob responsabilidade do administrador.

3.2 Operação gerencial

- CRUD de produtos, categorias, fornecedores, clientes e funcionários.
- Controle de quantidade, estoque mínimo, prateleira, preço, imagem e status do produto.
- Registro de lotes, validade e entradas de mercadoria com fornecedor, nota e custo.
- Movimentações de estoque por entrada, saída e ajuste; reposição e acompanhamento de estoque baixo.
- Consulta de vendas, cancelamento com motivo e devolução ao estoque, recibos e relatórios por período.
- Registro de número, série, chave, protocolo e status de documento fiscal.

3.3 Operação de balcão

- Consulta de produtos e disponibilidade.

- Cadastro/edição de clientes, montagem e atualização de carrinho.
- Finalização com dinheiro, PIX, débito ou crédito, cálculo de valor recebido e troco.
- Emissão/visualização de recibo e consulta de histórico do cliente e compras.

4. Requisitos funcionais

ID	Requisito	Prioridade	Critério de aceite resumido
RF-01	Autenticar usuários e direcionar por perfil.	Alta	Credenciais válidas abrem apenas a área permitida; inválidas geram mensagem sem expor dados.
RF-02	Isolar dados por farmácia.	Alta	Usuário de uma unidade não consulta, altera ou exclui registros de outra.
RF-03	Gerenciar catálogo e categorias.	Alta	Produtos podem ser criados, editados, inativados e associados a categoria, preço e estoque mínimo.
RF-04	Controlar lotes e validade.	Alta	Entradas registram lote/validade e a baixa prioriza lotes que vencem primeiro.
RF-05	Registrar entradas e movimentações.	Alta	Toda entrada/saída/ajuste registra produto, quantidade, usuário, tipo e data.
RF-06	Concluir vendas.	Alta	Venda valida itens e pagamento, grava totais, baixa estoque e gera recibo.
RF-07	Cancelar venda.	Alta	Venda concluída pode ser cancelada com motivo, usuário, data e devolução única ao estoque.
RF-08	Gerenciar clientes e históricos.	Média	CPF é único por farmácia e o histórico mostra vendas e produtos mais comprados.
RF-09	Emitir relatórios e exportar CSV.	Média	Relatórios filtram por período, exibem totais e permitem impressão/exportação.
RF-10	Auditar operações.	Alta	Evento registra perfil, ação, entidade, identificador, descrição, data e autor.
RF-11	Manter dados fiscais.	Média	Venda possui registro fiscal com status pendente, emitida, cancelada ou erro.
RF-12	Executar backup administrativo.	Média	Administrador consegue gerar backup e recebe indicação clara de sucesso ou falha.

5. Requisitos não funcionais

ID	Categoria	Requisito
RNF-01	Segurança	Senhas devem ser armazenadas com hash forte; consultas devem usar prepared statements e entradas devem ser validadas/escapadas.
RNF-02	Autorização	Cada endpoint deve validar autenticação, cargo e pertencimento à farmácia no servidor.

RNF-03	Integridade	Venda, itens, lotes e movimentações devem ser persistidos em transação, sem estoque negativo.
RNF-04	Disponibilidade	O sistema deve operar em container Apache/PHP 8.2 e MySQL compatível, com procedimento documentado de restauração.
RNF-05	Usabilidade	Interface responsiva em português do Brasil, com mensagens de validação e confirmação para ações destrutivas.
RNF-06	Rastreabilidade	Logs de auditoria devem ser protegidos contra alteração pelo usuário operacional e possuir retenção definida.
RNF-07	Privacidade	CPF, telefone, e-mail e dados de funcionários devem seguir princípio de mínimo acesso e política de retenção.
RNF-08	Manutenibilidade	Adicionar testes automatizados para autenticação, isolamento, vendas, cancelamento e estoque antes de produção.

6. Regras de negócio identificadas

1. Usuários gerente e balconista pertencem a exatamente uma farmácia; operações devem respeitar esse vínculo.
2. Apenas gerente pode executar as ações de cancelamento de venda, gerenciamento de estoque, relatórios e fiscal previstas no módulo de permissões.
3. Produtos podem ter categoria nula, mas devem possuir preço, prateleira e estoque mínimo.
4. Um lote é identificado de forma única por produto e número de lote e possui validade obrigatória.
5. Venda registra forma de pagamento entre dinheiro, PIX, débito e crédito, além de valor recebido e troco.
6. Venda cancelada não deve ser cancelada novamente; o motivo, operador e horário devem permanecer registrados.
7. CPF de cliente é único dentro da farmácia, não necessariamente na rede inteira.
8. Uma nota fiscal possui no máximo um registro por venda e seu status deve refletir o processamento fiscal.

7. Modelo de dados e integrações

O banco possui entidades para farmácias, administradores, usuários, categorias, produtos, lotes, clientes, vendas, itens, alocação de itens por lote, movimentações, fornecedores, entradas, notas fiscais e auditoria. As chaves estrangeiras e os campos de status dão suporte à rastreabilidade operacional.

Integração/superfície	Situação observada	Requisito complementar
Banco MySQL	DDL de instalação e script de atualização disponíveis.	Versionar migrações, credenciais fora do código e rotina de restauração testada.
Fiscal	Tela/modelo armazenam dados de NF-e/NFC-e.	Integração SEFAZ/provedor, certificado digital, contingência e tratamento de rejeições.
Agente de IA	Há API e JavaScript para o agente.	Definir escopo de dados acessíveis, autenticação, limites, logs e proteção contra prompt injection.
Backup	Funcionalidade administrativa de backup SQL.	Criptografia, armazenamento externo, retenção, testes de restauração e controle de download.

8. Lacunas, riscos e recomendações

Risco/lacuna	Impacto	Recomendação
Credenciais de exemplo no SQL e senhas aparentemente sem hash.	Alto	Remover credenciais padrão, forçar troca inicial e usar password_hash/password_verify.
Integração fiscal oficial não implementada.	Alto	Tratar a tela atual como registro auxiliar e contratar/definir provedor fiscal antes de emissão real.
Ausência de evidência de proteção CSRF e rate limiting.	Alto	Adicionar tokens CSRF, limitação de tentativas e expiração/regeneração de sessão.
Operações críticas exigem consistência concorrente.	Alto	Usar transações, bloqueio de linhas e testes simultâneos em venda/cancelamento.
Backup e dados pessoais podem ficar expostos.	Médio	Restringir acesso, criptografar arquivos, registrar downloads e definir retenção/LGPD.
Pouca evidência de testes automatizados e observabilidade.	Médio	Adicionar suíte de testes, logs estruturados, monitoramento e alertas de falha.
Requisitos de negócio não estão formalizados fora do código.	Médio	Validar este documento com responsáveis e transformar critérios em casos de teste.

9. Critérios de aceite prioritários

- Um usuário de uma farmácia não consegue manipular produto, cliente, venda ou estoque de outra, mesmo alterando parâmetros da URL.
- Uma venda com estoque insuficiente é rejeitada sem deixar registros parciais.
- Venda concluída atualiza produto, lote e movimentação de forma atômica.

- Cancelamento devolve exatamente as quantidades vendidas, registra motivo e impede duplicidade.
- Relatórios e auditoria respeitam o período, a unidade e o perfil do usuário.
- Falha no banco, no backup ou na integração fiscal é exibida como erro explícito, sem mensagem de sucesso falsa.

10. Roadmap recomendado

Fase	Entrega
1 — Segurança e integridade	Hash de senhas, CSRF, prepared statements, autorização por farmácia, transações e prevenção de estoque negativo.
2 — Qualidade operacional	Testes automatizados dos fluxos críticos, validações de formulário, mensagens de erro e logs estruturados.
3 — Fiscal e conformidade	Integração com provedor fiscal, certificado, contingência, LGPD, retenção e revisão de backup.
4 — Evolução	Observabilidade, métricas, notificações de estoque/validade, melhoria do agente de IA e documentação de usuário.

Nota metodológica: esta análise descreve requisitos observados e requisitos recomendados. Itens marcados como lacuna devem ser confirmados com o responsável pelo produto antes de serem tratados como compromisso de implementação.